P. Sumalavasavi
192372149

SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

## ASSESSMENT TOOL II- ASSIGNMENT

**COURSE CODE: ITA14** **COURSE NAME: Ethical Hacking**

**COURSE OUTCOME COVERED**

*CO1:* Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

## ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

***Code of Conduct:***

*I* P. Sumalavasavi (192372149) *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

**Rubrics**

| Criteria | Weightage | Level 4 – Exemplary | Level 3 – Proficient | Level 2 – Developing | Level 1 – Beginning |
|---|---|---|---|---|---|
| **Understanding of Problem Context** | 20 | Clearly understands the problem and accurately identifies all data-handling requirements and operations | Good understanding with minor gaps | Basic understanding; some requirements unclear | Poor understanding or misinterpretation of the problem |
| **Application of Concepts** | 30 | Accurately applies appropriate data structures and algorithms to solve complex problems | Applies relevant concepts correctly with minor errors | Applies basic concepts with limited accuracy | *Fails to apply* appropriate concepts |
| **Problem-Solving Approach** | 20 | Logical, well-structured, and efficient approach | Mostly logical approach with minor gaps | Basic approach with some inconsistencies | Illogical or unclear approach |
| **Accuracy of Solution** | 20 | Completely correct code, output and complexity analysis with proper justification | Mostly correct with minor errors | Partially correct solution | Incorrect or incomplete solution |
| **Clarity** | 10 | Clear, well-organized, and properly explained solution | Understandable with minor clarity issues | Limited clarity and explanation | Poorly presented and difficult to understand |

P. Sumalavasavi
192372149

11 A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.

Ans: As an ethical hacker, I would not exploit the critical vulnerability because the system is outside the clearly defined scope of the penetration test. Even though the vulnerability may pose a serious security task, exploiting it without proper authorization could damage the system, expose confidential information interrupt business operations, or create legal consequences.

Ethical hacking is the process of identifying and evaluating security weakness with the permission of the system owner. It follows important principles such as authorization, confidentiality, integrity, accountability, professional responsibility, and minimizing harm. An ethical hacker must always work within the limits agreed upon with the organization.

In this situation, the oneline email authorization is insufficient to establish clear boundaries for all testing activities. Before starting the engagement, I would request a formal written agreement that defines the target systems, permitted techniques, testing duration, limitations, reporting procedures, and responsibilities.

When I discover the vulnerability, I would stop any activity that could effect the system and record the available evidence without performing unauthorized exploitation. I would then inform the client through a secure communication channel and explain the possible consequence of the vulnerability. If further testing is necessary, I would request explicit written permission from the authorized owner. For example, suppose I am testing a company's website and discover a critical vulnerability in its payment server, which was not included in the agreed scope. I would not attempt to access payment records or modify transactions. Instead, I would report the discovery and recommend that the company authorize a seperate, controlled assessment.

Conclusion:

An ethical hacker must never assume that permission to test one system automatically grants permision to test one system automatically grants permission to test another. Clear authorization, respect for scope, responsible disclosure and haem prevention are essential for professional ethical hacking.

You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?

Ans: If I discover that a production database contains real customer financial information while testing a SQL injection vulnerability. I would proceed carefully to protect customer privacy and prevent damage to the organization's systems.

SQL injections is a security vulnerability that occurs when an application handles user input unsafely, allowing an attacker to interface with database queries. If exploited carelessly, it may allow unauthorized access to sensitive records, modification or deletion of information and disruption of database services.

If production testing is essential, I would confirm that the activity is explicitly authorized and use the least intrusive validation technique possible. I would avoid extracting actual customer records and stop immediately if the test causes unexpected behaviour or threatens service availability.

1. Written authorization and scope definition:

The client should provide written authorization identifying the systems, applications, databases and testing methods permitted. The agreement should also specify prohibited activities and condition

under which testing must stop.

2. Data protection and confidentiality:

The testing team must understand how sensitive customer information will be protected. Access to financial data should be avoided unless strictly unless necessary and specifically authorized. Any information, encountered must be handled according to the agreed confidentially requirements and applicable laws.

3. Use of a seperate testing environment:

Whenever possible, potentially dangerous tests should be performed in a staging environment containing synthetic data. This allows vulnerabilities to be examined without risking actual customer records.

4) Backup and recovery procedures:

Before testing, the organization should verify that reliable backups exist and that recovery procedure are available. The team should also identify the people responsible for restoring services if an unexpected incident occurs.

Conclusion: Ethical penetration testing must identify security weakness without unecessarily exposing customer information of disrupting business operations. Proper planning, written authorization, controlled testing, and responsible data handling are essential when assessing production databases.

During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this, and what your responsibility is now.

Ans: A denial-of-service (DoS) condition occurs when a system becomes unable to provide normal services because its resources are overwhelmed or exhausted. During a penetration test, accidentally triggering a DoS condition on a live production server can prevent legitimate users from accessing services and interuppt important bussiness activities.

As an ethical hacker, I am responsible for conducting testing carefully, minimizing disruption, and responding immediately if an unexpected incident occurs.

Preventive measures:

1) Clearly define the scope of testing:

Before beginning engagement, I would ensure that the client has specified the permitted systems, testing techniques and activities that could affect service availability. A general authorization should not be treated as permission to perform disruptive tests.

2) Avoid potentially harmful techniques.

High-volume requests, resource exhaustion attacks, and stress testing can affect server availability. Such activities should not be performed against production systems without explicit authorization, suitable

safeguards and clear testing plan.

3) Use a controlled environments

Potentially disruptive techniques should preferably be tested in a laboratory or staging environment. This allows the security team to observe system behaviour without affecting real user

4) Obtain approval for availability testing:

The client should explicitly approve any test that could affect system performance. Testing limits, acceptable resource usage and emergency stop conditions should be established before the activity begins.

Responsibilites after the outage:

If I accidentally cause a production outage, I would take the following actions.

1. stop the activity immedietly.
2. Inform the client
3. Assist with service recovery
4. Preserve the evidence of incident
5. Prepare the rp report of incident
6. Prevent the future incident by taking certain precautions.

A client ask you to test their Systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?

A client may want to evaluate whether ith IT depaetment can identify and repond to a realistic cyberattack without receiving advance warning. This type of security exercise is commonly associated with red team testing, which simulates attacker behaviour to assess the effectiveness of security controls, monitoring Systems and incident response procedures.

Although such testing can provide valuble information, conducting it without informing the appropriate personnal creates ethical, legal, operational and Organizational risks.

Ethical and Practical risks:

1. Operational disruption:

The IT team may mistake the simulated attack for a real security incident. They might isolate servers, disable applications or interupt Services while attempting to protect the organization

2. Legal consequences:

If the testes does not have clear written authorization, activities maybe interpreted as an unauthorized access or malicious behaviour. Permission must come from someone with authority.

3) 3) Incident escalation

Security personal may contact law enforcement, external incident responders, or service providers. An uncoordinated exercise may consume resources and interfere with the organization response to genuine threats.

4) Exposure of confidential information:

The simulated attack may encounter customer records, financial data, employee information, or other sensitive material. Such information must not be accessed or copied unnecessarily.

For exp example, a company may authorize a simulated phishing exercise without informing ordinary employees in advance. However, the organization should still establish appropriate approval.

Conclusion: A red team exercise can ethically test real-world detection capabilities without informing every member of the IT department However, it must have proper written authorization, Clearly defined rules, emergency safeguards, and responsible reporting

are asked to perform a "red team" exercise versus a vulnerability". Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics and rules of engagement would differ between the two.

Banks manage sensitive customer information, financial transactions, payment systems, physical premises and valuable assets. They must maintain strong security controls to prevent unauthorized access, financial fraud, data theft and service disruptions.

A. Red team Exercise:

A red team exercise simulates realistic attacker behaviour to evaluate how effectively an organization can prevent detect and respond to an attack. It focuses on understanding how an attacker might combine weakness across different systems or security layers to achieve an objective.

Real world Scenario:

Suppose a bank want to evaluate the effectiveness of its physical and digital security. The bank authorise a red team to access selected digital systems and designated physical areas

Within the approval scope, the team might simulate a phising attact against deignated employees, test and approved web applications security